AIエージェントシステムを対象とした ルールベース自動脅威モデリング手法

泰山 幸大[1]　東 拓矢[1]　大西 健斗[1]　中井 綱人[1]　小関 義博[1]

概要：近年，複数のツールや外部との相互作用を通じて自律的にタスクを遂行する AI エージェントが急速に普及し，メモリ汚染やツール誤用，エージェント間通信の汚染など従来のシステムにはない固有の攻撃面が生じている．こうしたリスクは設計段階での脅威モデリングによる体系的な分析が有効だが，AI エージェントシステム向けの分析は多くを分析者の人手に依存する．自動化の試みの多くは LLM による脅威生成に依存し，実行ごとに結果が揺らぎ導出根拠の追跡も難しい．これに対しデータフロー図（DFD）に基づくルールベースの手法は，同一の DFD から同一の結果が得られ，導出根拠をたどれる再現性と監査可能性をもつ．本研究では，DFD の作成には仕様書を読解できる LLM 等を用いたツールを利用して専門家でない利用者でも着手できるようにし，その DFD から脅威・影響・対策をルールで決定論的に導出する二段構成の脅威モデリング手法を提案する．脅威は OWASP が定義する AI エージェント固有の脅威，影響は MITRE ATLAS，対策は OWASP の緩和策・ガイドに基づいて対応づける．OWASP Multi-Agentic System Threat Modeling Guide に例示された RPA 経費精算システムへ適用し，同ガイドおよび人手の分析と比較したところ，同ガイドが MAESTRO の人手分析で挙げた主要な脅威をすべて導出でき，人手の分析に対して再現率 96%・一致率（Jaccard 係数）0.82 で一致し，人手が見落とした脅威も決定論的に補完できることを確認した．

キーワード：脅威モデリング，AI エージェント

A Rule-Based Automatic Threat Modeling Method for Agentic AI Systems

Kodai Taiyama[1]　Takuya Higashi[1]　Kento Oonishi[1]　Tsunato Nakai[1]　Yoshihiro Koseki[1]

Abstract: AI agents that autonomously accomplish tasks through interaction with multiple tools and their environment are rapidly spreading, introducing attack surfaces specific to agentic AI—such as memory poisoning, tool misuse, and agent communication poisoning—that do not exist in conventional systems. Such risks are effectively analyzed by threat modeling at design time, yet analysis for agentic AI systems still largely relies on manual effort. Most automation attempts depend on an LLM to generate threats, whose results vary from run to run and whose derivations are hard to trace. In contrast, data flow diagram (DFD)-based rule-based methods yield the same result for the same DFD and let each derivation be traced, providing reproducibility and auditability. In this paper we propose a two-stage threat modeling method: a DFD is created with the help of an LLM-based tool that reads the specification—so that even non-experts can get started—and threats, impacts, and countermeasures are then derived from that DFD deterministically by rules. Threats are mapped from OWASP-defined agentic-AI-specific threats, impacts from MITRE ATLAS, and countermeasures from OWASP mitigations and guides. Applying the method to the RPA expense-reimbursement system exemplified in the OWASP Multi-Agentic System Threat Modeling Guide and comparing it with the guide and with manual analysis, the method derived all the main threats that the guide identified through MAESTRO's manual analysis, matched the manual analysis with a recall of 96% and a Jaccard coefficient of 0.82, and also deterministically covered threats overlooked by the manual analysis.

Keywords: Threat Modeling, AI Agent

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

1.1 背景

ソフトウェアのセキュリティを確保するうえで，脆弱性が実装・運用段階で顕在化してから対処するのではなく，設計段階でリスクを体系的に洗い出す「シフトレフト」の考え方が重要とされている．その代表的な手法が脅威モデリングであり，対象システムをデータフロー図（DFD）などで抽象化し，構成要素ごとに STRIDE などの脅威分類を当てはめて脅威を列挙する [1], [2], [3]．DFD の構成要素と脅威カテゴリの組み合わせという網羅的な列挙により，分析者の主観に依存せず脅威の見落としを抑えられる点が特長である．

近年，LLM を中核として，外部ツールの呼び出しや環境との相互作用を通じて，与えられた目標を自律的に達成する AI エージェントが急速に普及している．従来の生成 AI が情報の生成や提示にとどまるのに対し，AI エージェントは自ら判断し，ツールや外部 API を介して現実世界に作用する点に特徴がある．このため，攻撃が成功した場合の被害は誤った出力にとどまらず，金銭の不正送金やデータの破壊といった実世界の損害に直結する．

さらに AI エージェントには，メモリ汚染やツール誤用，エージェント間通信の汚染など，従来のソフトウェアには存在しない固有の攻撃面が生じる．これらは自律的な判断や複数エージェントの連鎖，動的に変化する信頼境界といった特有の性質に起因し，従来の STRIDE のような分類だけでは捉えきれない．OWASP はこうした脅威を脅威カタログ「Agentic AI – Threats and Mitigations」として体系化し [4]，マルチエージェントシステム（Multi-Agentic System，以下，MAS）を対象とした脅威モデリングガイド（OWASP MAS Threat Modeling Guide，以下，MAS ガイド）[5] の整備も進んでいる．

一方で，これらの脅威を実際のシステムに当てはめて洗い出す脅威モデリングの作業は，依然として専門知識をもつ分析者の人手に大きく依存しており，属人的で，対象システムの規模が大きくなるほど負担が増し，脅威の抜け漏れも生じやすい．この負担を軽減するため脅威モデリングの自動化が進められているが，その試みの多くは LLM に脅威を生成させる方式に依存している [6], [7], [8]．LLM を用いる方式は柔軟である反面，実行ごとに出力が揺らいで再現性を欠き，ハルシネーションによる脅威の生成や取りこぼしも避けられず，導出根拠の追跡も難しい．脅威分析の結果は監査や意思決定の根拠となるため，これは重大な問題となる．

これに対し，脅威をルールとして定義し，DFD からルールに基づいて脅威を導出するルールベースの方式では，同一の DFD から同じ結果が得られ，各脅威がどのルールで導出されたかもたどれる．ただし，この方式は入力となる DFD を用意する必要があり，その作成自体が専門知識を要する点が障壁となる．そこで本研究では，DFD の作成には仕様書を読解できる LLM 等を用いたツールを利用し，得られた DFD から脅威・影響・対策をルールで決定論的に導出する二段構成の手法を提案する．脅威は OWASP の脅威カタログに基づいて導出し，影響は MITRE ATLAS を参考に整理し，対策は OWASP の緩和策およびガイドを参考に対応づける．DFD の作成をこうしたツールが補助することで専門家でない利用者でも脅威モデリングに着手でき，脅威・影響・対策の導出はルールベースなので出力は再現可能である．生成された DFD は人が確認・修正でき，修正後も同一のルールで導出するため，後段の再現性は損なわれない．

1.2 貢献

本研究の貢献は次の 3 点である．

(1) AI エージェントシステムの DFD を入力として，脅威・影響・対策を，LLM を用いずルールベースでマッピングする脅威モデリング手法を提案する．脅威にとどまらず影響と対策までを一つのパイプラインで対応づけ，同一の入力から同一の結果が得られる再現性と，導出根拠をたどれる監査可能性を確保する．

(2) 上記手法を実現する具体的なマッピングルール群を設計する．すなわち，DFD の構成要素と属性から脅威を導出する発火条件，OWASP 脅威カタログと MITRE ATLAS に基づく脅威と影響の対応，および OWASP の緩和策・ガイドに基づく脅威と対策の対応を，機械的に判定できる形で定義する．

(3) MAS ガイドに記載された RPA 経費精算のマルチエージェントシステムに本手法を適用し，同ガイドおよび人手による分析との比較を通じて，決定論的マッピングの網羅性と精度を検証する．

2. 前提知識

2.1 AI エージェント固有の脅威

OWASP Agentic Security Initiative は，AI エージェント固有の脅威を脅威カタログ「Agentic AI – Threats and Mitigations」として体系化し，T1〜T17 の脅威 ID で整理している [4]．さらに，マルチエージェントシステムを対象とした MAS ガイド [5] では，このカタログの脅威 ID とは別に，同ガイド独自の番号で特有の脅威が追加されている．また，脅威が顕在化した際の影響を分類する枠組みとして，AI システムへの攻撃の戦術・技術を体系化した知識ベースである MITRE ATLAS があり，本研究では，MITRE ATLAS の Impact 戦術に含まれるテクニックの具体例か

[1] 三菱電機株式会社 情報技術総合研究所
Information Technology R&D Center, Mitsubishi Electric Corporation

© 2026 Information Processing Society of Japan

表 1　AI エージェント脅威カタログ（T1〜T17）

ID	脅威名
T1	Memory Poisoning
T2	Tool Misuse
T3	Privilege Compromise
T4	Resource Overload
T5	Cascading Hallucination Attacks
T6	Intent Breaking & Goal Manipulation
T7	Misaligned & Deceptive Behaviors
T8	Repudiation & Untraceability
T9	Identity Spoofing & Impersonation
T10	Overwhelming Human in the Loop
T11	Unexpected RCE and Code Attacks
T12	Agent Communication Poisoning
T13	Rogue Agents
T14	Human Attacks on Multi-Agent Systems
T15	Human Manipulation
T16	Insecure Inter-Agent Protocol Abuse
T17	Supply Chain Compromise

ら被害の類型を抽出し，AI エージェントシステムにおける影響として整理した上で，各脅威に対応付ける．

OWASP の脅威カタログが整理する 17 種類の脅威（T1〜T17）を表 1 に示す．これらは，エージェントの記憶への不正な情報の注入（T1 Memory Poisoning），ツール呼び出しの不正利用（T2 Tool Misuse），エージェント間通信の汚染（T12 Agent Communication Poisoning）など，従来のソフトウェアには存在しない AI エージェント固有の攻撃面を捉えたものである．本手法は，これらを脅威の分類として用いる．

2.2　脅威モデリング

脅威モデリングとは，システムを設計段階でモデル化し，構成要素ごとに想定される脅威を体系的に洗い出す分析手法である [1], [2]．対象システムはしばしばデータフロー図（DFD）として表現され，外部エンティティ・プロセス・データストア・データフロー，およびそれらを隔てる信頼境界という要素に分解される．各要素に対し，代表的な脅威分類である STRIDE（なりすまし・改ざん・否認・情報漏えい・サービス拒否・権限昇格）[3] などの観点から脅威を列挙する．Microsoft が提供する Microsoft Threat Modeling Tool（MS-TMT）は，DFD の作図から STRIDE に基づく脅威の列挙までを支援する代表的なツールとして知られている．

一方，AI エージェントシステムを対象とした脅威モデリングの手法も提案されている．本研究が評価実験の比較対象とする MAS ガイド [5] は，脅威モデリング手法として MAESTRO[9] を採用している．MAESTRO は，AI エージェントシステムを 7 層の参照アーキテクチャに分解し，各層内および層間の相互作用に着目して脅威を分析する層別アプローチである．これに対し本研究は，システムを DFD の構成要素に分解し，構成要素と属性から脅威を決定論的に列挙する DFD ベースのアプローチを採る．層別分析が層間の相互作用の洗い出しに強みをもつ一方，本手法は MS-TMT と同じ構成要素×脅威の枠組みで機械的に脅威を導出でき，再現性と監査可能性を確保できる点に特徴がある．

2.3　関連研究

脅威モデリングの自動化は，労力削減と品質の均一化を目的に進められてきた [1], [2]．その方式は，脅威をルールとして定義し DFD などから決定論的に導出する方式と，LLM に脅威を生成させる方式に大別される．

ルールベースの方式では，Berger ら [10] が拡張 DFD 上で脅威をルール定義して自動抽出し，Da Silva ら [11] は Microsoft Threat Modeling Tool（MS-TMT）の STRIDE テンプレートを自動生成して ICS へ適用した．また，Scandariato ら [3] は，STRIDE に基づく脅威モデリングの生産性や偽陽性を実証的に評価している．特定ドメインへの展開も進み，Khalil ら [12] はサイバーフィジカルシステムへ STRIDE を体系適用し，Park ら [13] は MS-TMT に宇宙向けの SPARTA マトリクスを統合し，DFD から脅威を自動導出するツールを提案した．本研究はこの DFD ベースのルールベース手法の系譜を，AI エージェントシステムへ拡張したものと位置づけられる．

もう一方の，LLM を用いる方式でも，AI エージェントや LLM を対象とした脅威モデリング手法が提案されている．なかでも，DFD を入力に VLM と推論 LLM で拡張 STRIDE を生成する ASTRIDE[6] が学術的に最も近い．脅威分類の面では，MAS ガイド [5] を学術的に拡張した研究 [14] や，独自のタクソノミと対策を示す ATFAA/SHIELD[15] が提案されており，STRIDE と OWASP LLM/Agentic を相互にマッピングした MCP-38[16] も報告されている．実装ツールとしては，LLM 駆動の STRIDE GPT[7] や OWASP 公式の Let's Threat Model[8] が挙げられ，これらが直接の比較対象となる．

しかしこれらはいずれも，脅威生成を LLM に依存する [6], [7], [8] か，脅威の分類体系の提案にとどまり自動的なマッピング手法として確立されていない [14], [15], [16]．本研究は，(1)OWASP の AI エージェント脅威カタログ [4] を脅威の分類として用い，(2)DFD からルールベースで脅威をマッピングし，(3) 脅威にとどまらずその影響と対策までを一貫して対応づける点で，これらと異なる．特に，マッピングを担う後段では LLM を用いないため，この段階で出力が揺らぐことも，存在しない脅威が生成されることもなく，再現性と監査可能性を確保できる点に，本研究の特徴があると考えている．ここでいう監査可能性とは，マッピングが決定論的であるがゆえに，各脅威・影響・対

© 2026 Information Processing Society of Japan

策がどのルールから導出されたかを一意にたどれることを指す．

3. 提案手法

本手法のワークフローを図 1 に示す．本手法は，AI エージェントシステムの仕様書から DFD を生成する DFD 生成フェーズと，得られた DFD から脅威・影響・対策を導出するルールベースのマッピングフェーズの二段からなる．前段の DFD 生成は，仕様書や構成図の読解を要するため LLM 等を用いたツールの活用を想定する一方，後段のマッピングは LLM 等の AI を一切用いず，あらかじめ定義したルールのみで脅威・影響・対策を決定論的に導出する．これにより後段の出力は再現可能かつ監査可能となる．本論文が提案の対象とするのは後段のマッピングであり，以下では DFD の定義と各マッピングルールを述べる．

3.1 DFD の構成要素と属性の定義

本手法は，AI エージェントシステムの DFD を入力として受け取る．DFD は，User・Agent・Tool・LLM・DataStore・DataFlow・TrustBoundary のいずれかのコンポーネントの集合として構造化して記述し，各コンポーネントは脅威判定に用いる属性を持つ．

表 2 に，本手法が扱う構成要素と属性の定義を示す．属性は脅威の発火条件に用いられ，たとえば Agent の has_tools 属性はツール誤用系脅威（T2）の発火に，privilege_level 属性は権限侵害系脅威（T3）の発火に対応する．属性値は原則として bool 値または enum 値の 2 値で表現し，判定を機械的に行えるようにしている．enum 値をとる privilege_level は low と high の 2 値とし，付与の基準を操作的に定める．privilege_level は，参照・読み取りにとどまる Agent または Tool を low，データの書き込み・コマンド実行・外部システムへの作用を伴うものを high とする．このように基準を操作的に定めることで，分析者による属性値の付与を再現可能にしている．

3.2 脅威マッピングのルール

脅威マッピングのルールは，DFD の各コンポーネントの属性から，発火する脅威を決定論的に導出する．表 3 に，脅威ごとの発火条件と付与対象を示す．

たとえば T2（ツール誤用）は has_tools 属性が true である Agent に付与され，T17（サプライチェーン侵害）は external 属性が true である Tool または LLM に付与される．T4（リソース過負荷）や T5（カスケード型幻覚攻撃）のように，Agent が存在すれば常に付与される脅威もある．これらの条件はすべて DFD の属性値のみで判定でき，同一の DFD からは常に同一の脅威集合が得られる．

3.3 脅威の影響と対策のマッピングルール

発火した各脅威に対しては，さらにその影響と対策をマッピングする．いずれも脅威との対応をあらかじめルールとして定義しており，一つの脅威が複数の影響・対策に対応しうるため，各対応にはマッピング根拠を付与し，どの脅威からどの影響・対策が導かれたかを追跡できるようにしている．なお，本論文では手法の妥当性の検証を脅威の割り当てを対象に行うため，本節では影響と対策のマッピングの考え方のみを述べ，脅威ごとの具体的な対応の一覧は付録に示す．

影響の項目は，MITRE ATLAS の Impact 戦術に属する各テクニック（AML.T0029 や AML.T0048 など）が表す被害の類型を参考に，AI エージェントシステムの文脈に即して整理した．各脅威にこれらの影響項目を対応づけ，マッピング根拠の列にはその影響が生じる過程（影響のシナリオ）を記述する．各脅威にマッピングされる影響とその根拠を付録の表 A·1 および表 A·2 に示す．対策も同様に，「Agentic AI – Threats and Mitigations」の緩和策と OWASP Securing Agentic Applications Guide[17] を参考に，入出力の検証・アクセス制御・実行前の HITL 承認・異常検知など複数のカテゴリに分類し，脅威ごとに対応づけて付録の表 A·3 および表 A·4 に示す．これにより，各脅威に対する影響と対策が併記され，分析者は DFD を入力するだけで対策の検討に必要な情報を一貫して得られる．

4. 評価実験

本手法の有効性を確認するため，MAS ガイドに記載された RPA 経費精算のマルチエージェントシステムに本手法を適用し，同ガイドの脅威モデリング結果および人手による脅威割り当て結果と比較する．

4.1 実験設定

評価対象には，MAS ガイド [5] の第 3 章に例示された，RPA による経費精算のマルチエージェントシステムを用いた．本システムは，従業員が提出した領収書や申請フォームから情報を抽出し，RAG（Retrieval-Augmented Generation）を用いて経費規程との整合を検証し，承認された申請を支払処理へ回すワークフローを担う．

対象システムは 5 つのエージェントと 2 名のユーザ，および 4 つのデータストアから構成される．2 名のユーザは，申請者である Employee と承認者である Manager である．

MAS ガイドの例示は構成図と概要が中心で，仕様の記述に乏しいため，本手法の入力とする DFD は，同ガイドの Figure 2 の構成に忠実に従って人手で作成した．すなわち，同図に描かれたエージェント・ユーザ・データストアと，それらの間のデータフローを DFD の構成要素として写し取り，各構成要素に本手法が要求する属性を付与した．たとえば，ツールを介して金銭の移動や外部への作用を伴

© 2026 Information Processing Society of Japan

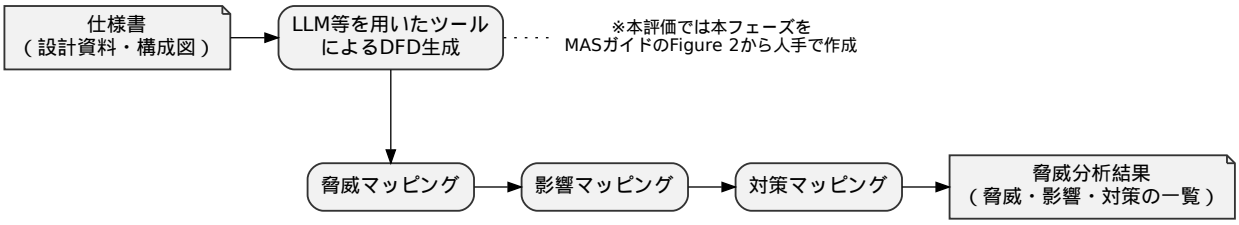


図 1 提案手法のワークフロー.

表 2 DFD の構成要素と属性の定義

コンポーネント	属性	型	値	脅威判定での役割
User	（属性なし）			
Agent	has_tools	bool	true / false	ツール誤用系脅威（T2）の発火
Agent	has_code_execution	bool	true / false	RCE 系脅威（T11）の発火
Agent	privilege_level	enum	low / high	権限侵害系脅威（T3）の発火
Tool	privilege_level	enum	low / high	高権限ツール使用時のリスク評価
Tool	external	bool	true / false	外部 API の場合サプライチェーン脅威（T17）考慮
DataStore	is_agent_memory	bool	true / false	true=内部メモリ→ T1 メモリ汚染の対象 false=外部知識ベース（RAG 等）は対象外
LLM	external	bool	true / false	外部 API 時にサプライチェーン脅威（T17）考慮
DataFlow	flow_type	enum	user_to_agent / agent_to_agent / agent_to_tool / agent_to_llm	from/to のコンポーネント種別を表す記述ラベル（脅威判定は from/to の実体で行う）
TrustBoundary	（属性なし）			信頼境界の区切りを表す （属性による脅威判定は行わない）

う Execution Agent と External Agent には privilege_level を high とした．また，データストアのうち Short-term Memory と Long-term Memory はエージェントの内部メモリとして is_agent_memory を true とし，Expense Policy DB は外部知識ベースとして区別した．さらに，社内のマルチエージェントシステムと外部サービスの間には信頼境界を設けた．なお，同図に LLM は独立した構成要素として現れないため，入力 DFD に LLM は置かず，サプライチェーン侵害（T17）は Tool（Finance System）の external のみで発火している．作成した DFD の構成を図 2 に示す．

図 2 に示すように，5 つのエージェントは，領収書を読み取る OCR Agent を起点に，Policy Validation Agent，Decision-Making Agent，Execution Agent へと処理が連鎖し，最終的に External Agent を経て外部の Finance System へ支払が実行される．各コンポーネントの役割と属性値を表 4 に示す．

4.2 手法の適用結果

図 2 の DFD の構成要素と属性を入力として脅威マッピングルールを適用したところ，本手法は 59 件の脅威を導出した．導出された各脅威には，対象コンポーネント・脅威 ID・影響・対策が対応づけられ，どのコンポーネントのどの属性からどのルールで導出されたかをたどれる．

4.3 MAS ガイドとの脅威モデリング結果比較

MAS ガイドは，同じ RPA 経費精算システムに対する脅威モデリングの過程と結果を記載している．その分析は二段階から成り，第一段階では OWASP の AI エージェント脅威カタログ「Agentic AI – Threats and Mitigations」[4] が定める脅威 ID を対象シナリオに直接あてはめてベースラインとなる脅威を列挙し，第二段階では MAESTRO[9] のレイヤー横断的な人手分析によってベースラインを超える追加の脅威を発見する．本例ではメモリ汚染やツール誤用，権限侵害，エージェント間通信汚染，マルチエージェントへの人間による攻撃などが挙げられている．このように，MAS ガイドは脅威カタログの直接適用と MAESTRO による人手分析を組み合わせて脅威を導出しており，DFD の構成要素と属性から決定論的に脅威を導出する本手法とは，導出の枠組みが根本的に異なる．

なお，MAS ガイドが脅威カタログから参照している脅威 ID は T1 から T15 にとどまるため，本節でも同じ T1 から T15 の範囲で両者を対応づける．

© 2026 Information Processing Society of Japan

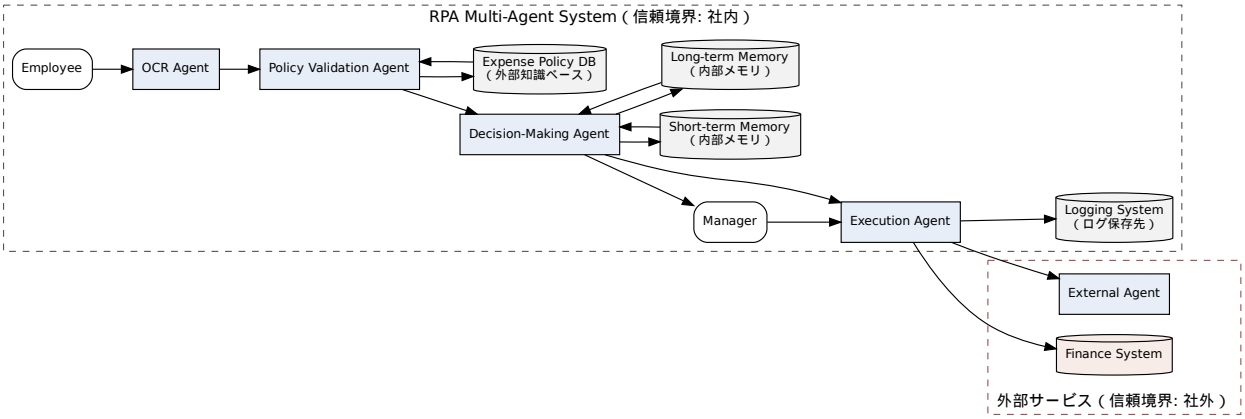


図 2 RPA 経費精算システムの DFD（OWASP MAS Threat Modeling Guide 第 3 章 Figure 2 準拠）

表 3 DFD から脅威へのマッピングルール（フローの条件は flow_type の値ではなく from/to の実体で判定する）

脅威	発火条件	付与対象
T1	DataStore.is_agent_memory = true	DataStore
T2	Agent.has_tools = true	Agent
T3	Agent.privilege_level = high	Agent
T4	DFD 上に Agent が存在	Agent
T5	DFD 上に Agent が存在	Agent
T6	DFD 上に Agent が存在	Agent
T7	DFD 上に Agent が存在	Agent
T8	DFD 上に Agent が存在	Agent
T9	DFD 上に Agent が存在	Agent
T10	agent→user フローを持つ Agent	Agent
T11	Agent.has_code_execution = true	Agent
T12	送信元・宛先が共に Agent の DataFlow（agent→agent）	DataFlow
T13	Agent 数 ≥ 2	Agent
T14	User 存在 AND agent→agent の DataFlow が存在	Agent
T15	user↔agent フロー（人間と直接接点）を持つ Agent	Agent
T16	送信元・宛先が共に Agent の DataFlow（agent→agent）	DataFlow
T17	Tool.external = true OR LLM.external = true	Tool・LLM

本節および次節での比較結果を，表 5 にまとめて示す．同表では，各コンポーネントに脅威を割り当てた主体を，本手法を A，人手を H，MAS ガイドを M で表し，複数の主体が割り当てた場合はその記号を併記する．本節ではこのうち M との対応に着目する．MAS ガイドは，メモリ汚染（T1）・ツール誤用（T2）・権限侵害（T3）・意図破壊と目標操作（T6）・欺瞞的振る舞い（T7）・否認と追跡不能性（T8）・HITL 圧倒（T10）・エージェント通信汚染（T12）・不正エージェント（T13）の 9 種の脅威を挙げており，脅威 ID 単位で対応づけると，これら 9 種はすべて本手法の出力にも含まれていた．本手法は決定論的なルールに基づき，MAS ガイドが人手のレイヤー分析で見いだした主要な脅威を，人手を介さずに導出できたといえる．ただし脅威を割り当てるコンポーネントの粒度は両者で異なる．たとえば MAS ガイドは HITL 圧倒（T10）を Manager に，否認と追跡不能性（T8）を Logging System に割り当てるのに対し，本手法は同種の脅威をエージェントに割り当てる．これは，MAESTRO がシステムをレイヤーとして捉えるのに対し，本手法が DFD の構成要素と属性を単位とすることの違いによる．表 5 で M のみが割り当てたセルは 4 つあるが，いずれもこの粒度の違いによるものであり，本手法が脅威を取りこぼしたことを意味しない．

4.4 人手での脅威モデリング結果比較

前節の MAS ガイドとの比較が同ガイドの参照範囲である T1 から T15 にとどまったのに対し，本節では脅威カタログ全体である T1 から T17 を対象に，決定論的マッピングの網羅性と精度を検証する．同一の DFD を対象に，本論文の著者の一人が人手でコンポーネントごとに脅威を割り当てた結果と本手法の出力を比較した．この著者には，本手法と同じ DFD の構成要素一覧を提示し，本手法の出力を参照せずに，各コンポーネントに該当すると考える脅威を割り当てるよう求めた．本手法（A）と人手（H）の割り当てをコンポーネント単位で対応づけ，表 5 で比較する．

割り当ての総数は，本手法が 59 件，人手が 52 件であり，このうち 50 件は両者が一致した．人手が割り当てた 52 件のうち本手法が捕捉したのは 50 件であり，人手基準での再現率は 96%であった．両者の和集合 61 件に対する一致率（Jaccard 係数）は 0.82 であり，本手法の割り当てが人

© 2026 Information Processing Society of Japan

表 4　RPA 経費精算システムの構成要素と属性（本手法への入力 DFD）

種別	名称（略称）	役割	主要属性
ユーザ	Employee	経費を申請する従業員	（属性なし）
	Manager	承認を行う監督者（HITL）	（属性なし）
エージェント	OCR Agent（OCR）	領収書からデータを抽出	has_tools=false, has_code_execution=false, privilege=low
	Policy Validation Agent（PV）	経費規程に照合し合否を推論	has_tools=false, has_code_execution=false, privilege=low
	Decision-Making Agent（DM）	承認/却下/エスカレーションを判断	has_tools=false, has_code_execution=false, privilege=low
	Execution Agent（Exec）	承認済み申請を経理 API へ送信・支払	has_tools=true, has_code_execution=false, privilege=high
	External Agent（Ext）	外部で支払処理を自律実行	has_tools=true, has_code_execution=false, privilege=high
データストア	Short-term Memory	エージェントの短期記憶	is_agent_memory=true（内部メモリ）
	Long-term Memory	エージェントの長期記憶	is_agent_memory=true（内部メモリ）
	Expense Policy DB	経費規程の参照 DB	is_agent_memory=false（外部知識ベース）
	Logging System	操作ログの保存先	is_agent_memory=false（ログ保存先）
ツール	Finance System	外部の経理・支払システム	privilege=high, external=true
信頼境界	社内（Internal）	社内のマルチエージェントシステム	Employee, Manager, OCR, PV, DM, Exec, 各メモリ, Logging を含む
	社外（External）	外部サービス	Ext, Finance System を含む

手による分析と高い水準で一致することを確認した．

両者が食い違ったのは，本手法のみが割り当てた 9 件と，人手のみが割り当てた 2 件である．本手法のみが割り当てた 9 件の内訳は，カスケード型幻覚攻撃（T5）が 1 件，意図破壊と目標操作（T6）が 2 件，欺瞞的振る舞い（T7）が 2 件，HITL 圧倒（T10）が 1 件，人間操作（T15）が 3 件である．これらはエージェントの存在や人間との接点から機械的に付与される脅威であり，人手では一部のエージェントで見落とされていた．すなわち決定論的マッピングは，分析者の主観や注意力に依存せず条件を満たす脅威を漏れなく列挙できる．一方，人手のみの 2 件は，Policy Validation Agent と Decision-Making Agent に対する権限侵害（T3）である．本手法はこれらの privilege_level を high とせず T3 を付与しなかったが，人手は権限を伴う操作とみなした．この差は属性値（privilege_level）の付与が導出結果を左右することを示しており，属性付与の基準の明確化が今後の精度向上につながる．

5. 制約と今後の課題

本研究の評価は単一の事例に対するものであり，比較に用いた人手の脅威割り当ても本論文の著者の一人によるものである点が制約として残る．そのうえで今後の課題は大きく二つある．第一に，本手法の入力となる DFD の作成の支援である．本手法の出力の妥当性は入力 DFD の品質に依存するが，本研究では DFD を MAS ガイドの構成図から人手で作成した．今後は，仕様書や構成図からの DFD の生成と属性の付与を，LLM 等を用いたツールの活用を含めて支援する仕組みを検討する．第二に，多様な AI エージェントシステムへの適用を通じたルールおよび DFD 定義の改善である．今後はより多くの対象システムや，著者以外の独立した分析者を用いた比較評価を重ね，その結果をもとに脅威マッピングルールや DFD のコンポーネント・属性の定義を継続的に見直していく．

6. まとめ

本研究では，AI エージェントシステムの DFD を入力として，OWASP が定義する AI エージェント固有の脅威，MITRE ATLAS に基づくその影響，および対策を，LLM を用いずルールベースで決定論的に自動マッピングする脅威モデリング手法を提案した．RPA 経費精算のマルチエージェントシステムに適用した結果，本手法は 59 件の脅威を導出し，MAS ガイドが MAESTRO の人手分析で挙げた主要な脅威をすべて網羅するとともに，人手の分析に対して再現率 96%・一致率（Jaccard 係数）0.82 で一致した．また，同一の DFD から常に同一の結果が得られる再現性と，各導出根拠を一意にたどれる監査可能性を確認した．

参考文献

[1] Xiong, W. and Lagerström, R.: Threat Modeling – A Systematic Literature Review, *Computers & Security*,

© 2026 Information Processing Society of Japan

表 5 本手法・人手・MAS ガイド（MAESTRO）による脅威割り当ての比較
A=本手法，H=人手，M=MAS ガイド，–=いずれも割り当てず

種別	コンポーネント	T1	T2	T3	T4	T5	T6	T7	T8	T9	T10	T11	T12	T13	T14	T15	T16	T17
ユーザ	Manager	–	–	–	–	–	–	–	–	–	M	–	–	–	–	–	–	–
エージェント	OCR Agent	–	–	–	AH	A	A	AM	AH	AH	–	–	–	AH	AH	A	–	–
	Policy Validation Agent	–	–	H	AH	AH	AH	AHM	AH	AH	–	–	–	AH	AH	–	–	–
	Decision-Making Agent	–	–	H	AH	AH	AHM	AHM	AH	AH	A	–	–	AH	AH	A	–	–
	Execution Agent	–	AHM	AH	AH	AH	A	AM	AH	AH	–	–	–	AH	AH	A	–	–
	External Agent	–	AH	AH	AH	AH	AH	AH	AH	AH	–	–	–	AH	AH	–	–	–
データストア	Short-term Memory	AHM	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–
	Long-term Memory	AHM	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–
	Expense Policy DB	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–
	Logging System	–	–	–	–	–	–	–	M	–	–	–	–	–	–	–	–	–
データフロー	OCR→PV	–	–	–	–	–	–	–	–	–	–	–	AH	–	–	–	AH	–
	PV→DM	–	–	–	–	–	–	–	–	–	–	–	AH	–	–	–	AH	–
	DM→Exec	–	–	–	–	–	–	–	–	–	–	–	AH	–	–	–	AH	–
	Exec→Ext	–	–	–	–	–	–	–	–	–	–	–	AHM	M	–	–	AH	–
	Exec→Fin	–	–	M	–	–	–	–	–	–	–	–	–	–	–	–	–	–
外部	Finance System	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–	–	AH

Vol. 84, pp. 53–69 (online), DOI: 10.1016/j.cose.2019.03.010 (2019).

[2] Tuma, K., Calikli, G. and Scandariato, R.: Threat Analysis of Software Systems: A Systematic Literature Review, *Journal of Systems and Software*, Vol. 144, pp. 275–294 (online), DOI: 10.1016/j.jss.2018.06.073 (2018).

[3] Scandariato, R., Wuyts, K. and Joosen, W.: A Descriptive Study of Microsoft's Threat Modeling Technique, *Requirements Engineering*, Vol. 20, No. 2, pp. 163–180 (online), DOI: 10.1007/s00766-013-0195-2 (2015).

[4] OWASP Agentic Security Initiative: Agentic AI – Threats and Mitigations (v1.0), Technical report, OWASP GenAI Security Project (2025). https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/ (参照 2026-07-27).

[5] OWASP GenAI Security Project: Multi-Agentic System Threat Modeling Guide (v1.0), Technical report, OWASP (2025). https://genai.owasp.org/resource/multi-agentic-system-threat-modeling-guide-v1-0/ (参照 2026-07-27).

[6] Bandara, E., Hass, A., Gore, R., Shetty, S., Mukkamala, R. et al.: ASTRIDE: A Security Threat Modeling Platform for Agentic-AI Applications, arXiv preprint arXiv:2512.04785 (2025). https://arxiv.org/abs/2512.04785 (参照 2026-07-22).

[7] Adams, M.: STRIDE GPT: An AI-powered threat modeling tool, GitHub repository. https://github.com/mrwadams/stride-gpt (参照 2026-07-22).

[8] OWASP: OWASP Let's Threat Model (v1.0.0), OWASP project / GitHub repository (2025). https://github.com/OWASP/www-project-lets-threat-model (参照 2026-07-22).

[9] Huang, K.: Agentic AI Threat Modeling Framework: MAESTRO, Cloud Security Alliance Blog (2025). https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro (参照 2026-07-27).

[10] Berger, B. J., Sohr, K. and Koschke, R.: Automatically Extracting Threats from Extended Data Flow Diagrams, *Engineering Secure Software and Systems (ESSoS 2016), LNCS 9639*, pp. 56–71 (online), DOI: 10.1007/978-3-319-30806-7_4 (2016).

[11] Da Silva, M., Puys, M., Thevenon, P.-H., Mocanu, S. and Nkawa, N.: Automated ICS Template for STRIDE Microsoft Threat Modeling Tool, *Proc. 18th Int. Conf. on Availability, Reliability and Security (ARES 2023)*, (online), DOI: 10.1145/3600160.3605068 (2023).

[12] Khalil, S. M., Bahşi, H., Dola, H. O., Korõtko, T., McLaughlin, K. and Kotkas, V.: Threat Modeling of Cyber-Physical Systems – A Case Study of a Microgrid System, *Computers & Security*, Vol. 124, p. 102950 (online), DOI: 10.1016/j.cose.2022.102950 (2023).

[13] Park, J., Kwak, J., Baek, G., Kang, D. and Kim, S.: Towards Automated Threat Modeling for Space Systems via SPARTA Matrix, *Proc. Workshop on the Security of Space and Satellite Systems (SpaceSec 2026), co-located with NDSS 2026*, San Diego, CA, USA (2026). https://www.ndss-symposium.org/wp-content/uploads/spacesec26-67.pdf (参照 2026-07-22).

[14] Krawiecka, K. and Schroeder de Witt, C.: Extending the OWASP Multi-Agentic System Threat Modeling Guide: Insights from Multi-Agent Security Research, arXiv preprint arXiv:2508.09815 (2025). https://arxiv.org/abs/2508.09815 (参照 2026-07-22).

[15] Narajala, V. S. and Narayan, O.: Securing Agentic AI: A Comprehensive Threat Model and Mitigation Framework for Generative AI Agents, arXiv preprint arXiv:2504.19956 (2025). ATFAA / SHIELD. https://arxiv.org/abs/2504.19956 (参照 2026-07-22).

[16] Shen, Y. T., Toyoda, K. and Leung, A.: MCP-38: A Comprehensive Threat Taxonomy for Model Context Protocol Systems, arXiv preprint arXiv:2603.18063 (2026). https://arxiv.org/abs/2603.18063 (参照 2026-07-22).

[17] OWASP GenAI Security Project: Securing Agentic Applications Guide (v1.0), Technical report, OWASP (2025). https://genai.owasp.org/resource/securing-agentic-applications-guide-1-0/ (参照 2026-07-31).

© 2026 Information Processing Society of Japan

付　　録

A.1　脅威と影響のマッピング

本手法は脅威に加えてその影響と対策まで一貫して導出するが，本論文では脅威の割り当てを中心に論じたため，影響と対策の具体的なマッピングの一覧を本付録に補足する．まず，各脅威にマッピングされる影響とマッピング根拠を表 A·1 および表 A·2 に示す．

A.2　脅威に対する対策の分類

各脅威に対応づけられる対策を表 A·3 および表 A·4 に示す．対策は，「Agentic AI – Threats and Mitigations」[4] に記載された緩和策と，OWASP Securing Agentic Applications Guide[17] を参考に作成し，大項目に分類して整理している．

© 2026 Information Processing Society of Japan

表 A·1 脅威と影響のマッピング（前半）

脅威	影響	マッピング根拠
T1 Memory Poisoning	意思決定の歪み・操作	メモリに注入された悪意データが意思決定プロセスを歪める
	データセット汚染・有用性低下	メモリ/ベクトル DB の内容が汚染され信頼性が低下する
	データ破壊・可用性喪失	メモリの大規模汚染によりシステムの正常動作が不能になる
T2 Tool Misuse	データ破壊・可用性喪失	ツールの不正操作によりデータが破壊される
	経済的損害（窃盗・詐欺）	ツール経由で金融操作や不正送金が実行される
	エージェント権限の不正利用	ツールを通じてエージェント権限が悪用される
T3 Privilege Compromise	システム完全侵害	権限昇格により任意の操作が可能になる
	経済的損害（窃盗・詐欺）	高権限操作により直接的な経済被害が発生する
	プライバシー侵害・データ漏洩	権限悪用により機密データにアクセスされる
	エージェント権限の不正利用	エージェントの権限が直接悪用される
T4 Resource Overload	AI サービス停止・劣化	リソース枯渇によりサービスが停止する
	運用コスト異常増大	過剰リソース消費によりコストが増大する
	リソース枯渇による連鎖障害	リソース枯渇が他サービスに連鎖する
T5 Cascading Hallucination Attacks	意思決定の歪み・操作	幻覚情報に基づく誤った意思決定が実行される
	組織の評判・信頼毀損	誤情報の拡散により組織の信頼が低下する
	業務効率低下・手動作業化	AI 出力の信頼性低下により手動確認が必要になる
T6 Intent Breaking & Goal Manipulation	意思決定の歪み・操作	エージェントの目標が操作され意図しない行動が実行される
	データ破壊・可用性喪失	操作されたエージェントが破壊的行動を実行する
	経済的損害（窃盗・詐欺）	目標操作により不正な金融取引が実行される
T7 Misaligned & Deceptive Behaviors	意思決定の歪み・操作	目標に整合しない戦略が隠密に形成される
	組織の評判・信頼毀損	欺瞞的行動が発覚した場合に組織の信頼が毀損する
	社会的損害の拡散	有害な行動がユーザーや社会に影響を与える
T8 Repudiation & Untraceability	組織の評判・信頼毀損	説明責任の欠如により信頼が損なわれる
	システム完全侵害	追跡不能により侵害の検知・対応が遅延する
T9 Identity Spoofing & Impersonation	プライバシー侵害・データ漏洩	なりすましにより機密情報にアクセスされる
	経済的損害（窃盗・詐欺）	なりすましにより詐欺行為が実行される
	システム完全侵害	なりすましによりシステム全体が侵害される

© 2026 Information Processing Society of Japan

表 A·2 脅威と影響のマッピング（後半）

脅威	影響	マッピング根拠
T10 Overwhelming Human in the Loop	意思決定の歪み・操作 業務効率低下・手動作業化	人間の監督が無効化され不正な意思決定が見逃される 監督プロセスが機能不全に陥る
T11 Unexpected RCE and Code Attacks	システム完全侵害 データ破壊・可用性喪失 プライバシー侵害・データ漏洩	任意コード実行によりシステムが完全に侵害される 悪意あるコードによりデータが破壊される コード実行によりデータが外部に送信される
T12 Agent Communication Poisoning	意思決定の歪み・操作 AI サービス停止・劣化 リソース枯渇による連鎖障害	偽情報が通信経由で拡散し意思決定を歪める 通信操作によりワークフローが妨害される 通信汚染がシステム全体に連鎖障害を引き起こす
T13 Rogue Agents	プライバシー侵害・データ漏洩 システム完全侵害 組織の評判・信頼毀損	不正エージェントがデータを外部に流出させる 不正エージェントが監視外で不正操作を実行する 不正エージェントの行動が組織の信頼を毀損する
T14 Human Attacks on Multi-Agent Systems	エージェント権限の不正利用 経済的損害（窃盗・詐欺） システム完全侵害	連鎖認可の悪用でエージェント権限が越権利用される 越権操作（例: 支出限度額の不正変更）で直接的な経済被害が生じる Confused Deputy により本来拒否される操作がバックエンドで実行される
T15 Human Manipulation	ユーザー個人への被害 経済的損害（窃盗・詐欺） 社会的損害の拡散	ユーザーが操作され個人的被害を受ける 操作されたユーザーが不正に金銭を支払う AI 信頼を悪用した大規模な人間操作が社会に影響する
T16 Insecure Inter-Agent Protocol Abuse	意思決定の歪み・操作 エージェント権限の不正利用 プライバシー侵害・データ漏洩	プロトコル欠陥を通じてエージェントが不正に操作される プロトコル悪用によりエージェント権限が奪取される プロトコル脆弱性を通じてデータが漏洩する
T17 Supply Chain Compromise	サプライチェーン汚染の波及 システム完全侵害 AI 検知機能の回避	悪意あるコンポーネントが多数のシステムに感染する 汚染されたコンポーネント経由でシステムが侵害される 改ざんされた AI モデルが検知を回避する

© 2026 Information Processing Society of Japan

表 A·3 脅威に対する対策の分類（前半）

大項目	具体的な対策	関連脅威
モデル選定	低ハルシネーション・真実性の高いモデル選定	T5
	指示追従性・整合性の高いモデル選定	T6, T7
入出力検証・サニタイズ	入力の正規化・危険文字/特殊トークン除去・サニタイズ	T1, T2, T3, T16
	PII 検出・マスキング	T1
	スキーマ/許可リストによる引数・型検証・フェイルクローズ	T2, T16
	SQL インジェクション対策 (パラメータ化クエリ/ORM)	T2
	出力フィルタ・モデレーション (有害/操作的応答の遮断)	T15
	出力の真実性・事実整合性チェック	T1, T5
	データフロー追跡による非信頼データ制御 (CaMeL 等)	T2, T3, T6
プロンプト・エージェント堅牢化	システムプロンプトの堅牢化 (禁止事項・運用範囲明記・構造化入力埋め込み)	T2, T7, T15
	コア指示の上書き耐性・プロンプトロック	T1, T6
	目標・意図の固定 (インテントカプセル・目標変更の承認)	T6
アクセス制御・権限管理	RBAC/ABAC・最小権限による権限定義	T1, T2, T3, T13
	読み取り専用既定・書込明示付与・DB アクセス限定	T1, T3, T5
	ユーザ権限引継ぎ (コンテキスト境界追跡)	T1, T3, T6, T7
	API アクセス制御 (ゲートウェイ・OAuth スコープ・限定 API キー)	T2, T3, T6
	一時的権限付与・JIT アクセス・短命トークン	T2, T3, T9, T16
	データ分類・機密ラベル・DLP・最小化	T1, T3
認証・ID・身元検証	資格情報の安全な取得・シークレット管理・ローテーション	T3, T9, T15
	エージェント認証 (mTLS/JWT/OAuth・OIDC/DID・VC)	T9, T13, T14, T16
	固有マシン ID 割り当て・ライフサイクル管理	T9, T13
	リクエスト署名・暗号学的アイデンティティ証明 (RFC9421/ANS)	T9, T13, T16
	多要素認証 (MFA)・継続的再認証	T2, T3
	ゼロトラスト (送信元によらず全アクセス検証)	T3, T9, T12
実行前検証・HITL（人間の承認）	重要/不可逆操作の HITL 承認・MFA・dry-run diff 提示	T2, T3, T6, T11
	計画・意図の実行前検証・ポリシーエンジンによる検証	T3, T5, T6
	リスクベース HITL 設計・監督レベルの動的調整	T7, T10, T15
	プレビュー/実行の分離・リスクバッジ・確信度表示	T10
	監督担当者の教育・ユーザーへの注意喚起	T10
	物理インターロック・ロックダウン・報告手段	T7
隔離実行・サンドボックス	ツール/コード実行のサンドボックス隔離・実行後リセット	T2, T3, T11, T17
	ネットワーク分離・エアギャップ・セグメンテーション	T3, T5, T6
	Web/ブラウザのサンドボックス化・URL 許可リスト・SSRF 対策	T2, T6, T7
	非信頼データ処理の隔離 (メモリ分離ランタイム)	T1, T6
	システムコール制限 (seccomp/AppArmor/SELinux)・読取専用ボリューム	T11, T17
ランタイムセキュリティ・ポリシー適用	I/O ガードレール・動的ポリシー適用 (OPA 等)	T2, T11, T12, T13
	プロンプトインジェクション実行時検知	T2, T11, T16
	実行時 DAST・CVE/ポートスキャン・パッチ管理	T11

© 2026 Information Processing Society of Japan

表 A·4 脅威に対する対策の分類（後半）

大項目	具体的な対策	関連脅威
レート制限・リソース制御	レート制限・タイムアウト (HITL/ツール/API/エージェント間)	T2, T4, T7, T10
	CPU/メモリ/実行時間の上限・名前空間/コンテナ制限	T4, T17
	全エージェント横断のリソース消費追跡	T4
	サーキットブレーカ・自動スケール・隔離による自動対応	T4, T10
異常検知・監視	メモリ/状態の異常検知 (更新頻度・サイズ・内容)	T1
	ツール利用の異常検知 (頻度・不審引数・機微呼び出し)	T2, T11
	リソース・レートの異常検知	T4
	挙動ドリフト・目標逸脱・性能低下の検知 (Baseline 比較)	T5, T6, T7, T15
	エージェント間通信・共謀・創発挙動の検知 (Watchdog)	T12, T13, T14
	信頼スコア・信頼性からの逸脱検知	T13, T14
	人間の承認バイアス・判断反転の検知	T10, T15
	AI 行動監査 (別モデルによる行動チェック)	T6
ログ出力・監査・追跡性	構造化ログ (推論・計画・ツール呼び出し・HITL 判断)	T1, T8, T11
	改ざん検知可能・追記専用ログ (HMAC/Merkle/署名)	T5, T8, T13, T15
	行為の帰属 (on-behalf-of・ID/権限の記録・トレース ID)	T3, T8
	系統情報・知識リネージの追跡	T1, T5
	アクセスログ完全性検証・相関分析	T5, T13
インシデント対応・封じ込め	インシデント対応計画 (封じ込め・ロールバック・訓練)	T1, T8, T12, T13
	キルスイッチ・即時停止・隔離	T2, T12, T13, T14, T17
	資格情報失効・信頼ベースライン再確立・再統合前の再検証	T13, T14
テスト・レッドチーミング	レッドチーミング (汚染/注入/共謀/意図操作の再現)	T1, T2, T6, T7, T12, T13
	ふるまい/耐性ベンチマーク評価 (HELM/AgentBench 等)	T2, T4, T5
	ファジング・ペンテスト	T2, T11
通信保護・プロトコル検証	通信の暗号化・認証 (TLS/Noise/mTLS/E2E 暗号化)	T13, T16
	プロトコル/スキーマ検証・バージョン固定・ダウングレード拒否	T16
	証明書ピンニング・前方秘匿性	T16
	トラフィック解析対策	T16
サプライチェーン・完全性検証	セキュアコーディング・eval 禁止・タイントラッキング	T11
	SAST/DAST/SCA 統合パイプライン・コードレビュー	T11, T12, T17
	コード署名・来歴追跡・SBOM(AIBOM)・ハッシュ固定	T12, T13, T17
	更新の完全性検証・段階的展開・差分テスト・自動ロールバック	T12, T13, T17
	エージェント/ツールのディスカバリ制限 (信頼レジストリ限定)	T14, T16, T17
	行動マニフェスト・証明によるエージェント検証	T13, T14
トラスト境界・分離	ゼロトラスト境界・ネットワーク分割・コンテナ隔離	T12, T13, T14
	信頼ゾーン割り当て・ゾーン間通信の厳格制御	T14
	制御チャネルの保護・レジストリ境界分離	T14
	レピュテーションスコア・新規エージェント追加制限	T12, T13
耐障害性	コンポーネント障害/侵害を前提とした耐障害設計	T5, T17

© 2026 Information Processing Society of Japan